

Cybersecurity Daily Newsletter

Vol. 005 | 2026-09-26 09:00 WIB

Top 5 Highlights

- 3 Consulting Myths Debunked by Unit 42 Experts
- Bitget loses \$351.6 million in suspected North Korean crypto hack
- Researchers identify AliExpress-themed phishing campaign using disposable domains
- Compromised GitHub Actions re-enabled, posing supply chain risks
- New PamStealer variant uses server-side decryption for macOS malware

Threat Intelligence (10)

01. Researchers identify AliExpress-themed phishing campaign using disposable domains

EfficientIP Research Labs identified potential .cyou domains on June 9 that were later registered and began resolving to IP addresses on July 2.

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Tighten email authentication and filtering, run targeted user awareness, and monitor for lookalike domains and suspicious inbox rules.

Sources: <https://www.scworld.com/brief/researchers-identify-aliexpress-themed-phishing-campaign-using-disposable-domains>

02. Compromised GitHub Actions re-enabled, posing supply chain risks

The compromised GitHub Actions were originally disabled on May 18, 2026, after being found to execute malicious code that harvested sensitive credentials from CI/CD pipelines.

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Audit build pipelines, rotate CI/CD secrets, enforce package integrity controls, and review developer workstation hardening.

Sources:

<https://www.scworld.com/brief/compromised-github-actions-re-enabled-posing-supply-chain-risks>

03. New PamStealer variant uses server-side decryption for macOS malware

The latest PamStealer variant, observed by Jamf Threat Labs, continues to use a JavaScript for Automation (JXA) dropper but has updated its lure and delivery mechanisms.

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Update detections and threat hunts using reported TTPs/IOCs, review email/web controls, and harden high-risk internet-facing services.

Sources:

<https://www.scworld.com/brief/new-pamstealer-variant-uses-server-side-decryption-for-macos-malware>

04. Fake Google Security Team ad says 'no script reading' in voice phishing - then prints the script

More mockery and memes from the Dark Web Roast

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Tighten email authentication and filtering, run targeted user awareness, and monitor for lookalike domains and suspicious inbox rules.

Sources: <https://www.theregister.com/security/2026/09/25/fake-google-security-team-ad-says-no-script-rendering-in-voice-phishing-then-prints-the-script/5299264>

05. Kothamine malware uses Tailscale's tailcat to evade network detection

Kothamine uses a legitimate Tailscale tool to receive attackers' commands through an encrypted connection with no malicious domain to block.

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Update detections and threat hunts using reported TTPs/IOCs, review email/web controls, and harden high-risk internet-facing services.

Sources: <https://www.malwarebytes.com/blog/threat-intel/2026/09/kothamine-malware-uses-tailscales-tailcat-to-evade-network-detection>

06. With the Rise of AI Agents, SOC 2 Should Adapt or Risk Irrelevance

AI agents can operate through human credentials and take actions that existing SOC 2 controls may not distinguish from human activity. Token Security explains why SOC 2 needs to adapt to address the security gaps created by agent identities. [...]

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Update detections and threat hunts using reported TTPs/IOCs, review email/web controls, and harden high-risk internet-facing services.

Sources: <https://www.bleepingcomputer.com/news/security/with-the-rise-of-ai-agents-soc-2-should-adapt-or-risk-irrelevance/>

07. Compromised GitHub Actions Came Back Online and Resumed Executing Mini Shai-Hulud Malware

Two actions-cool GitHub Actions have been disabled for a second time after the repositories became accessible last week, months after they were compromised during the May 2026 Mini Shai-Hulud campaign. The affected GitHub Actions are listed below - actions-cool/issues-helper actions-cool/maintain-one-comment Visiting either of the repositories now shows the...

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Update detections and threat hunts using reported TTPs/IOCs, review email/web controls, and harden high-risk internet-facing services.

Sources: <https://thehackernews.com/2026/09/compromised-github-actions-came-back.html>

08. PamStealer macOS Malware Adds Live C2 Payload Decryption and Multi-Layer Persistence

Cybersecurity researchers have flagged a new version of PamStealer that ensures that the main payload can only be recovered using a server-side decryption chain. The latest artifacts, per Jamf Threat Labs, continue to rely on the same JavaScript for Automation (JXA) dropper mechanism, but modify the lure and the delivery method. "Where earlier variants embe...

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Update detections and threat hunts using reported TTPs/IOCs, review email/web controls, and harden high-risk internet-facing services.

Sources: <https://thehackernews.com/2026/09/pamstealer-macos-malware-adds-live-c2.html>

09. A Closer Look at Malware From the Macfinger ClickFix Campaign, (Fri, Sep 25th)

Introduction

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Update detections and threat hunts using reported TTPs/IOCs, review email/web controls, and harden high-risk internet-facing services.

Sources: <https://isc.sans.edu/diary/rss/33368>

10. [+24h Old] RemControl Banking Trojan Gives Attackers Remote Control of Android Devices

The newly-discovered trojan abuses the Android Accessibility Service to gain control over victim devices and collect sensitive banking credentials

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Update detections and threat hunts using reported TTPs/IOCs, review email/web controls, and harden high-risk internet-facing services.

Sources: <https://www.infosecurity-magazine.com/news/banking-trojan-remote-control/>

Latest Vulnerabilities (10)

01. 3 Consulting Myths Debunked by Unit 42 Experts

Unit 42 security experts address critical cybersecurity misconceptions, offering practical insights to help your organization reinforce its enterprise defenses. The post 3 Consulting Myths Debunked by Unit 42 Experts appeared first on Unit 42 .

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources: <https://unit42.paloaltonetworks.com/3-consulting-myths-debunked-by-unit-42-experts/>

02. Vulnerable OBS overlay and Chromium flaw enable Twitch chat message code execution

The attack targets streamers using OBS Studio version 32.2.2 or older, exploiting a cross-site scripting (XSS) flaw in custom Twitch chat overlays that insert viewer messages directly into the page as unsanitized HTML.

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources: <https://www.scworld.com/brief/vulnerable-obs-overlay-and-chromium-flaw-enable-twitch-chat-message-code-execution>

03. Elementor plugin vulnerability allows admin account creation

Threat actors can exploit this flaw by tricking a logged-in administrator into clicking a malicious link.

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources: <https://www.scworld.com/brief/elementor-plugin-vulnerability-allows-admin-account-creation>

04. New Carbonato botnet uses AI framework to target insecure Docker daemons

Carbonato exploits Docker hosts with unauthenticated API access on port 2375.

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources: <https://www.scworld.com/brief/new-carbonato-botnet-uses-ai-framework-to-target-insecure-docker-daemons>

05. ShinyHunters hacked Clop leak site using Grav CMS path traversal flaw

The Clop ransomware gang has moved its data leak site to a new Tor address after confirming its previous server was compromised and defaced through an unpatched Grav CMS flaw that BleepingComputer has learned is an unauthenticated path traversal vulnerability. [...]

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources: <https://www.bleepingcomputer.com/news/security/shinyhunters-hacked-clop-leak-site-using-grav-cms-path-traversal-flaw/>

06. Elementor WordPress flaw lets attackers create admin accounts

A cross-site request forgery (CSRF) vulnerability in the Elementor plugin for WordPress could allow an unauthenticated attacker to create administrator accounts. [...]

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources: <https://www.bleepingcomputer.com/news/security/elementor-wordpress-flaw-lets-attackers-create-admin-accounts/>

07. AI tools help hacker break in for \$25 per target

It's cheap to set yourself up as a hacker these days using AI. Someone attacked 105 online retailers over a period of five days, compromising 27 of them - all for an average of \$25 per attack, according to research by Israeli security company Gambit...

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources: <https://www.csoonline.com/article/4226861/ai-tools-help-hacker-break-in-for-25-per-target.html>

08. CISA warns of Sharepoint, WSO2, Adobe Commerce flaws exploited in attacks

The Cybersecurity and Infrastructure Security Agency (CISA) warns that hackers are exploiting a critical authentication bypass vulnerability (CVE-2026-5430) affecting multiple products from enterprise software provider WSO2. [...]

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources: <https://www.bleepingcomputer.com/news/security/cisa-warns-of-sharepoint-wso2-adobe-commerce-flaws-exploited-in-attacks/>

09. Documentation placeholder domain used in ClickFix attacks

The domain name third-party[.]com is being used to serve malware to users - bad news for those following a little too literally online documentation that uses it as a placeholder for any third-party domain. The site is serving a ClickFix lure to Windows machines, which sidesteps existing protection and can effect changes to PowerShell, according to Manifold...

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources: <https://www.csoonline.com/article/4226782/documentation-placeholder-domain-used-in-clickfix-attacks.html>

10. VU#699627: Readwise Reader for Android, version 8.7.2, contains multiple XSS vulnerabilities

Overview Three cross-site scripting (XSS) vulnerabilities identified in Readwise Reader for Android version 8.7.2 are disclosed. An attacker with the ability to craft malicious

documents or metadata can exploit these vulnerabilities by supplying poisoned content that bypasses sanitization. Successful exploitation could allow the attacker to execute arbitrar...

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources: <https://kb.cert.org/vuls/id/699627>

Data Breach & Cybercrime (10)

01. Bitget loses \$351.6 million in suspected North Korean crypto hack

The breach was discovered on Thursday evening when security systems detected unauthorized transfers.

Why it matters: Breaches and cybercrime activity signal where attackers are focusing and what data types are actively monetized.

Recommendation: Validate incident-response readiness, monitor for exposed credentials, and reinforce MFA, phishing resistance, and data-loss controls.

Sources:

<https://www.scworld.com/brief/bitget-loses-351-6-million-in-suspected-north-korean-crypto-hack>

02. Cloudflare Containers vulnerability allowed data leakage

The flaw resided in Cloudflare's use of thin provisioning for container disks, where deleted container blocks were returned to a shared pool without being wiped.

Why it matters: Breaches and cybercrime activity signal where attackers are focusing and what data types are actively monetized.

Recommendation: Validate incident-response readiness, monitor for exposed credentials, and reinforce MFA, phishing resistance, and data-loss controls.

Sources: <https://www.scworld.com/brief/cloudflare-containers-vulnerability-allowed-data-leakage>

03. U.S. Soldier Gets 70 Months in Prison for AT&T, Verizon Extortions

A U.S. Army soldier who pleaded guilty to hacking into multiple telecommunications companies and stealing mobile call and text metadata for more than 100 million AT&T customers in 2024 was sentenced to 70 months in federal prison today and ordered to pay nearly \$300,000 in restitution to victims.

Why it matters: Breaches and cybercrime activity signal where attackers are focusing and what data types are actively monetized.

Recommendation: Validate incident-response readiness, monitor for exposed credentials, and reinforce MFA, phishing resistance, and data-loss controls.

Sources:

<https://krebsonsecurity.com/2026/09/u-s-soldier-gets-70-months-in-prison-for-att-verizon-extortions/>

04. ShinyHunters tells The Reg: We hacked the FBI to 'protect our business'

Data theft and extortion biz, that is

Why it matters: Breaches and cybercrime activity signal where attackers are focusing and what data types are actively monetized.

Recommendation: Validate incident-response readiness, monitor for exposed credentials, and reinforce MFA, phishing resistance, and data-loss controls.

Sources: <https://www.theregister.com/cyber-crime/2026/09/25/shinyhunters-tells-the-reg-we-hacked-the-fbi-to-protect-our-business/5299250>

05. In Other News: Clop Leak Site Takeover, Docker Botnet Hunts AI Keys, Water Utility Exposure

Noteworthy stories that might have slipped under the radar: BragJack attack against browser AI assistants, TDengine flaw threatens industrial telemetry uptime, Ubuntu update overhaul. The post In Other News: Clop Leak Site Takeover, Docker Botnet Hunts AI Keys, Water Utility Exposure appeared first on SecurityWeek .

Why it matters: Breaches and cybercrime activity signal where attackers are focusing and what data types are actively monetized.

Recommendation: Validate incident-response readiness, monitor for exposed credentials, and reinforce MFA, phishing resistance, and data-loss controls.

Sources: <https://www.securityweek.com/in-other-news-clop-leak-site-takeover-docker-botnet-hunts-ai-keys-water-utility-exposure/>

06. LinkedIn adds new checks for fake profiles and work histories

The platform is adding new checks as AI makes profiles easier to forge. But scammers can still invent a company to recruit for.

Why it matters: Breaches and cybercrime activity signal where attackers are focusing and what data types are actively monetized.

Recommendation: Validate incident-response readiness, monitor for exposed credentials, and reinforce MFA, phishing resistance, and data-loss controls.

Sources: <https://www.malwarebytes.com/blog/news/2026/09/linkedin-adds-new-checks-for-fake-profiles-and-work-histories>

07. Kosovar Owner of Rydlox Marketplace Pleads Guilty in US Court

Ardit Kutleshi created and operated Rydlox, which allowed miscreants to trade PII and cybercrime tools and services. The post Kosovar Owner of Rydlox Marketplace Pleads Guilty in US Court appeared first on SecurityWeek .

Why it matters: Breaches and cybercrime activity signal where attackers are focusing and what data types are actively monetized.

Recommendation: Validate incident-response readiness, monitor for exposed credentials, and reinforce MFA, phishing resistance, and data-loss controls.

Sources: <https://www.securityweek.com/kosovar-owner-of-rydlox-marketplace-pleads-guilty-in-us-court/>

08. Rydlox marketplace admin pleads guilty, faces 22 years in prison

A Kosovar national has pleaded guilty to operating Rydlox, a large illegal online marketplace that sold stolen personal information, login credentials, credit card details,

and cybercrime tools. [...]

Why it matters: Breaches and cybercrime activity signal where attackers are focusing and what data types are actively monetized.

Recommendation: Validate incident-response readiness, monitor for exposed credentials, and reinforce MFA, phishing resistance, and data-loss controls.

Sources: <https://www.bleepingcomputer.com/news/security/rydoox-marketplace-admin-pleads-guilty-face-s-22-years-in-prison/>

09. Windows, Linux, Android File Notification Systems Leak User Activity

Researchers show that file-change notification systems can leak keystroke timing, browsing activity, and WhatsApp media events. The post Windows, Linux, Android File Notification Systems Leak User Activity appeared first on SecurityWeek .

Why it matters: Breaches and cybercrime activity signal where attackers are focusing and what data types are actively monetized.

Recommendation: Validate incident-response readiness, monitor for exposed credentials, and reinforce MFA, phishing resistance, and data-loss controls.

Sources:

<https://www.securityweek.com/windows-linux-android-file-notification-systems-leak-user-activity/>

10. Bitget Says Suspected North Korean Hackers Stole \$351.6M After Backend Compromise

Cryptocurrency exchange Bitget said suspected North Korean threat actors have stolen \$351.6 million from its hot and warm wallets. "At 18:31 UTC on September 24, 2026, Bitget's security systems identified unauthorized transfers involving a limited number of hot wallets," BitGet said in a post shared on X. "Bitget's cold wallets and the overwhelming majority...

Why it matters: Breaches and cybercrime activity signal where attackers are focusing and what data types are actively monetized.

Recommendation: Validate incident-response readiness, monitor for exposed credentials, and reinforce MFA, phishing resistance, and data-loss controls.

Sources: <https://thehackernews.com/2026/09/bitget-says-suspected-north-korean.html>